

TLP:CLEAR

Анализ угроз на основе ханипотов

Ежемесячный отчёт — август 2026

LLM-ханипот под эксплуатацией | VNC-кампания на ICS | SNMP-отражение | SSH-ботнеты | Смена канала VPSVAULT | Фишинг: тренды

Параметр	Значение
Период отчёта	1-31 августа 2026 (2026-08-01 — 2026-09-01 UTC)
Дата анализа	1 сентября 2026
Классификация	TLP:CLEAR
Уровень угрозы	ВЫСОКИЙ
Узлы ханипотов	DE, US, RU + IEC-104/VNC (ICS/OT) приманка
Объём событий	≈2,06-2,08 млн атакующих сессий/запросов по всем сервисам (+50% к июлю)
SSH-события	720 374 сессии, 604 549 неудачных логинов, 517 payload-загрузок
VNC-события (ICS)	≈1,30 млн подключений, 1 279 302 попытки подбора пароля
LLM-абьюз (Ollama)	92 241 событие, 46,5% объёма от одного источника
Образцы малвари	≈180 уникальных артефактов (оценка с поправкой на методику подсчёта)

1. Краткое заключение

За август 2026 три ханипот-узла общего назначения (Германия, США, Россия) плюс отдельная приманка промышленного сегмента (протокол IEC-104, VNC remote-desktop и веб-интерфейс устройства) зафиксировали порядка 2,06-2,08 млн атакующих сессий и запросов — на 50% больше июля. Рост охватил почти все категории, но самый крупный вклад (Dionaea/SMB, +129%) частично отражает не рост числа атак, а особенность подсчёта: один и тот же перехваченный файл-вредонос при обрыве передачи по SMB каждый раз получает новый хеш и засчитывается как отдельное событие.

Заголовок месяца — открытый LLM-сервер (Ollama) перестал быть простым счётчиком сканирований. Через известное семейство уязвимостей CVE-2024-37032 («Problama») пошёл систематический traversal к облачным учётным данным, SSRF в облачные metadata-сервисы, попытка записи SSH-ключа в файл авторизованных ключей и дефейс-кампания с вымогательской запиской внутри системного промпта модели. Впервые появилась целевая разведка Anthropic-совместимых прокси — операторы ищут шлюзы с чужими API-ключами. Почти половину объёма месяца (46,5%) даёт один источник на санкционированном хостинг-провайдере. Операторы также впервые стали проверять подлинность ханипота специальными промптами — обоснованная гипотеза риска для всего класса LLM-приманок, но пока не наблюдаемый эффект (падения потока нет).

На промышленной приманке кампания подбора пароля к VNC не остановилась, а сменила состав: доминировавшая в июле автономная система замолчала с 21 августа, её место заняли широкий облачный кластер и новая группа из двенадцати географически разрозненных хостов, включившихся синхронно. Ни одной успешной аутентификации за месяц не зафиксировано. Отдельно приманку использовали трижды как усилитель SNMP-отражения — два из трёх эпизодов (13-16 августа) по объёму почти в 33 раза превышают эпизод, ранее разобранный отдельно. Промышленный протокол IEC-104 третий месяц подряд не получил ни одной внешней управляющей команды: реальный вектор в этот сегмент — не сам протокол АСУ ТП, а средства удалённого доступа.

В SSH-сегменте на первое место по весу брутфорса вышел новый оператор; известный дроппер-канал вырос в 15,5 раза; кампания-мимикрия перепаковывает бинарь под каждый запрос, обходя детект по хешу; самая технически зрелая кампания месяца сочетает SSH-персистентность, майнер Monero, кражу приватного SSH-ключа и полную доставку по SFTP — атрибуцию этой кампании к известной APT-группе по одному источнику MalwareBazaar мы не подтверждаем и не используем. Оператор Docker-червя, известный по предыдущим отчётам, не исчез при падении объёма Docker-трафика на 34% — он перенёс основной канал доставки на прямой SSH-брутфорс при той же инфраструктуре, а его текущий командный сервер оставался активным непрерывно весь период с 12 по 31 августа.

Впервые в серии месячных отчётов — раздел о фишинге. Мы отслеживаем почтовые ящики нескольких партнёрских организаций по их запросу; в августе против одной из них одновременно и независимо действовало восемь и более операторов (против трёх в июле). Главная тенденция — не техника, а инфраструктура: посадочные страницы и эксфильтрация всё чаще уходят на легитимные сторонние SaaS-платформы, а не на собственный хостинг атакующих, два канала доставки в

августе обошлись вообще без подделки отправителя, и один из операторов развернул рабочий adversary-in-the-middle-прокси перед логином Google, который крадёт сессионную куку и обходит многофакторную аутентификацию.

2. Поправки к предыдущей отчётности

Опубликованная в отчёте за июль 2026 цифра «193 552 попытки подбора пароля к VNC» была получена подсчётом за первые 10 суток месяца, а не за весь июль. Пересчёт по полному сырому логу даёт реальный июльский объём — 1 218 442 попытки. Сравнение «рост в несколько раз» между июлем и августом, основанное на прежней цифре, неверно: при честном сопоставлении полных месяцев рост в абсолюте умеренный (см. §4), в суточной интенсивности — заметнее. Везде ниже используется исправленная июльская база.

Отдельно подтверждаем ранее не отражённый факт: второй этап Docker-червя, описанного в наших июньском и июльском отчётах, был детонирован ещё в начале июля. Вторая стадия оказалась DDoS-ботом семейства Mirai, а не криптомайнером, как предполагалось на раннем этапе анализа; в цепочке управления обнаружено третье звено. Отдельной публикации по этой кампании не выходило — это первое исправление ранее неверно указанного статуса детонации.

3. Инфраструктура наблюдения

Флот состоит из трёх ханипот-узлов общего назначения (Германия, США, Россия), эмулирующих SSH/Telnet, SMB/MSSQL/MySQL/FTP/SIP, Docker API, MikroTik RouterOS (Winbox), Kubernetes (Kubelet) и открытый LLM-эндпоинт (Ollama), плюс отдельная приманка промышленного сегмента, эмулирующая протокол IEC-104, VNC remote-desktop и веб-интерфейс устройства ABB. Публичные адреса, хостинг-провайдеры и внутренние идентификаторы узлов не раскрываются. Все узлы флота отработали август без простоев, заметных со стороны атакующих; германский узел LLM-приманки впервые дал полный календарный месяц данных (в июле он был включён не с первого числа), что делает август первым сопоставимым трёхузловым месяцем для этого сервиса.

4. Сводка объёмов

Суммарный объём атакующих сессий и запросов по трём узлам общего назначения за август — порядка 2,06-2,08 млн против ≈1,37 млн в июле (+50%). SSH (Cowrie), точные счётчики:

Метрика	DE	US	RU	Август	Июль	Δ
Сессии	337 790	206 901	175 683	720 374	657 706	+9,5%
Успешные логины	9 295	1 823	4 304	15 422	17 674	-12,7%
Неудачные логины	280 295	181 864	142 390	604 549	554 964	+8,9%
Команды в shell	8 951	3 980	9 084	22 015	10 437	+111%
Скачанные payload-ы	355	162	0	517	351	+47%
SFTP-загрузки	49	38	0	87	49	+78%
direct-tcpip (прокси)	13 886	739	1 082	15 707	25 792	-39%
Success rate	3,2%	1,0%	2,9%	—	—	—

Число сессий выросло скромно, а команд в шелле — вдвое: боты стали чаще доводить сессию до полезной нагрузки, а не бросать её сразу после логина. Уникальных SSH-источников за месяц — около 20 000 (июль ≈18 600, +8%). Прочие сервисы, точные счётчики:

Сервис	DE	US	RU	Август	Июль	Δ
Dionaea (SMB/MSSQL/MySQL/FTP/SIP)	620 636	184 998	301 620	1 107 254	484 296	+129 %
Docker API	44 488	40 922	37 406	122 816	185 347	−34%
Winbox (MikroTik)	1 783	1 798	10 785	14 366	10 017	+43%
Kubelet (k8s)	1 199	1 278	396	2 873	3 634	−21%

Ollama (LLM): 92 241 событие за август — без сравнения с июлем, так как один из узлов был неполный месяц в строю ещё в июле. Разбор — §5. Уникальных источников: Docker ≈1 450 (июль ≈2 480, −41% — кампания сузилась числом участников при неизменном ядре), Kubelet ≈550, Ollama ≈1 470-1 490.

Рост Dionaea (+129%) — крупнейший вклад среди «прочих сервисов», но требует методической оговорки: механизм частичных SMB-захватов одного и того же файла-вредоноса (WannaCry) создаёт разные хеши на каждый обрыв передачи, из-за чего счётчик событий не позволяет напрямую отделить рост числа заражённых хостов от изменения того, что засчитывается как событие. Рост объёма подтверждён счётчиком; читать его как пропорциональный рост интенсивности атак нельзя.

Снижение объёма Docker API (−34%) — не спад активности прежнего оператора, а смена канала доставки на прямой SSH-брутфорс при сохранении инфраструктуры и дропзоны; разбор — §8.

Промышленная приманка, агрегат по сырым логам:

Сервис	Август	Июль (испр.)	Δ
VNC-подключения	1 295 134 - 1 304 763	1 256 816	+3-4%
VNC, попытки пароля	1 279 302	1 218 442	+5,0%
SNMP-запросы	380 315 - 380 412	10 027	×38
Веб-интерфейс устройства (HTTPS)	36 319	56 702	−36%
IEC-104, все строки	1 730 - 1 812	2 156	−16...20%
— из них внешние	759	1 081	−30%
— внешние управляющие команды	0	0	третий месяц подряд ноль

Окна наблюдения в июле и августе отличаются по длине на несколько часов, поэтому абсолютные цифры VNC-кампании занижают рост интенсивности: в пересчёте на сутки подключения выросли примерно на 9-10%, попытки пароля — примерно на 7%. Разбор кампании — §6.

5. Заголовок месяца: LLM-ханипот под активной эксплуатацией

Ollama-приманка зафиксировала за август 92 241 событие (точный 30-суточный счётчик) от 1 469-1 486 уникальных источников. 46,5% всего объёма месяца дал один источник — санкционированный хостинг-провайдер (AS210644, зарегистрирован в РФ), гоняющий 12 923 идентичных запроса «What is 3+3?». Ценность месяца не в объёме, а в качестве: разведка и инвентаризация каталога моделей остаются основным классом событий, но впервые рядом с ними появилась работающая техника эксплуатации.

Через эндпоинты `/api/pull` и `/api/create` — семейство уязвимостей CVE-2024-37032 («Problama») — пошёл систематический traversal к облачным учётным данным: `../../root/.aws/credentials`, `root/.config/gcloud/application_default_credentials.json`, `/proc/self/environ`, `/etc/passwd` — не проверка уязвимости, а целевая охота за секретами. Отдельный источник прячет SSRF-запрос к metadata-сервисам AWS/GCP в поле имени модели. Замечены go-template-инъекции (`{{readFile "/etc/passwd"}}`), попытка записи в `~/.ssh/authorized_keys` через имя модели — имплант ключа, а не только чтение файлов, — и проба переполнения парсера формата GGUF аномально большим значением параметра контекста.

Отдельная кампания-вымогатель: два источника создают на захваченном сервере модели с именами `gpt-4o:latest` / `claude-3-opus:latest` / `gpt-4:latest` из локальной tinyllama, системный промпт которых — записка о выкупе с BTC-адресом. Пассивная проверка на конец месяца — ноль транзакций: кампания не приносит денег, но остаётся дефейсом чужой инфраструктуры.

Охота на Anthropic-совместимые прокси — новое явление августа, отсутствовавшее в июле. Сотни запросов на пути вида `/v1/messages` и `/anthropic/v1/messages` с характерным заголовком `anthropic-version`, к моделям вида `claude-opus-4` и через облачные обёртки (Bedrock, OpenRouter). Заголовки авторизации подтверждают гипотезу: массово встречается захардкоженный дефолтный master-key одного из популярных LLM-гейтвеев и заведомо фиктивные токены — операторы систематически ищут, не стоит ли за открытым LLM-портом шлюз с чужим Anthropic-ключом.

Телеметрия по назначению нагрузки указывает как минимум на три разных сценария монетизации краденого inference — это интерпретация назначения промптов, а не подтверждённая организационная модель: бот для ставок на прогнозном рынке, источник, похожий на китайскую контент-ферму, и пайплайн, по характерным промптам напоминающий функцию долговременной памяти чат-бота-компаньона. Из телеметрии уверенно следует только вероятное назначение нагрузки; бизнес-модель и происхождение данных остаются гипотезой.

Индустриализация видна и в самих сканерах: специализированные user-agent-строки находят открытый эндпоинт, проверяют его живость, оценивают качество ответа модели, включают в пул и периодически перепроверяют. Отдельно замечено подключение стороннего AI-агента для кодирования напрямую к захваченному серверу — сигнал, что открытые LLM-серверы уже встроены в чужие рабочие пайплайны, а не только сканируются.

По путям запросов лидируют /api/tags (17 112) и /api/generate (11 079), далее /api/version (8 616), /v1/models (2 901), /v1/chat/completions (2 687) — сигнатура промышленной верификации эндпоинтов (перечислить модели → контрольный промпт → занести в пул). По моделям — локальные llama3.1:8b (10 447), qwen2.5:7b (1 570), codellama:13b (789), но качественный сдвиг в том, что атакующие ровно перебирают весь каталог платных облачных моделей сервиса (около 30 разных моделей по 20-36 обращений каждая) — систематическая инвентаризация, а не случайные пробы.

Операторы также впервые начали проверять подлинность ханипота специальными верификационными промптами (запрос назвать модель-строителя, проверка стойкости к prompt injection, запрос вернуть контрольную фразу дословно). Сам факт таких запросов подтверждён телеметрией; вывод «ханипот попадёт в чёрные списки пулов, и поток данных иссякнет» — обоснованная гипотеза риска для всего класса LLM-приманок, а не наблюдаемый эффект: падения потока или прямых признаков занесения в чёрные списки в данных месяца нет.

6. ICS-подстанция: VNC-кампания сменила состав, SNMP-отражение — три эпизода

Кампания подбора пароля к VNC (порт 5900) шла весь месяц. По честному пересчёту (§2) абсолютный объём вырос умеренно: 1 279 302 попытки против 1 218 442 (+5,0%), но в суточном пересчёте (окна разной длины) рост заметнее — около 42 117 попыток в сутки против 39 305 (+7,2%/сут), подключения — 44 380/сут против 40 543/сут (+9,5%/сут). Кампания не стоит на месте — интенсивность растёт, хотя и не взрывным темпом.

При этом состав кампании изменился радикально. Автономная система, доминировавшая в июле, дала лишь три коротких включения и полностью замолчала с 21 августа: в одном из последних окон (18-20 августа) она дала 269 212 попыток, после чего почасовой ряд обрывается практически до нуля — либо закончился арендованный пул адресов, либо оператор переключился на другую цель (ключевой вопрос для сентября). Круглосуточную нагрузку теперь несёт широкий облачный кластер (285 адресов на двух крупных азиатских облачных провайдерах) — в июле эти же адреса были незаметным «длинным хвостом», а за месяц выросли на порядок и стали основой кампании. Плюс новая группа из двенадцати хостов, каждый в своей автономной системе и своей стране (включая несколько абонентских/резидентных сетей), включившихся синхронно с уходящим оператором и проработавших ещё трое суток после его исчезновения. Один из двенадцати лежит в том же адресном блоке /24, что источники SSH-брутфорса, наблюдавшиеся месяцем ранее, — повторяющийся во флоте источник второй месяц подряд.

Подбор пароля не увенчался успехом ни разу: ноль записей об успешной аутентификации за месяц, ни одной подтверждённой строки о принятом пароле в сыром логе, ни одного успешного входа на веб-портал устройства.

SNMP-отражение (усиление ответов приманки против третьих лиц) — серия из трёх эпизодов:

#	Окно (UTC)	Пакетов	Темп	Спуфленные источники
A	13.08, 11 мин	103 607	≈223 pps	≈20 адресов
B	14-16.08, ≈47 ч	255 070	≈1,45 pps	9-13 адресов
C	28.08, 41 сек	10 837	≈265 pps	848 адресов, 6 блоков /24

				одной автономной системы
--	--	--	--	--------------------------

Эпизоды А и В суммарно дают 358 677 запросов — примерно в 33 раза больше эпизода С, который ранее уже разбирался отдельно, и оба прошли до установки защитных мер (вечером 28 августа). Совокупность признаков подтверждает подделку исходных адресов: отбойные ICMP-сообщения от «источников», отсутствие какой-либо TCP-истории у них, арифметически регулярный шаг между сгенерированными адресами в одном из диапазонов — та же подпись инструмента, что и в эпизоде С, связывающая все три эпизода как работу одного и того же генератора трафика. Усиление измерено по объёму ответа: около 8,03× по размеру payload.

Промышленный протокол IEC-104 третий месяц подряд не даёт ни одной внешней управляющей команды. Топ-источники внешних событий — массовая облачная переписка доступных в интернете устройств (крупные облачные платформы, известные исследовательские сканеры) без концентрации на одном акторе. Практический вывод остаётся неизменным: реальный вектор входа в подобный сегмент — не сам промышленный протокол, а средства удалённого доступа персонала.

7. SSH и ботнеты

Смена главного оператора SSH-брутфорса. Июльский топ состоял из одиночных источников; в августе один оператор дал 21,5% всего веса SSH-брутфорса флота — порядка 90 IP-адресов в пяти блоках /24, присутствие ежедневное весь месяц.

Известный дроппер-канал вырос со 139 до 2 163 обращений (×15,5): один и тот же адрес одновременно брутфорсит SSH, доставляет полезную нагрузку и сам себе служит дроппер-сервером — без ротации инфраструктуры, оператор не опасается блокировки.

Отдельный источник маскируется под системные демоны: 16+ разных бинарей под именами вида telnetd, sshd, kworker, systemd, dbus и т.д. Почти каждый URL отдаёт два разных хеша между запросами — сервер перепackовывает бинарь на лету, детект по хешу против этой кампании бесполезен.

Крупнейший дроппер-оператор месяца добавил второй адресный блок /24 к уже известному: три мультиархитектурных набора инструментов, классический профиль Mirai/Gafgyt.

Самая технически зрелая кампания августа сочетает SSH-персистентность и майнер Monero: заливку приватного SSH-ключа, зачистку конкурирующих процессов, установку неснимаемого атрибута на каталог ~/.ssh, доставку целиком по SFTP (пять архитектур, 27 файлов sshd с 27 разными хешами — перепackовка под каждую жертву). Детект по URL-дропперу против неё не работает по построению. Отдельно отмечаем: метка известной APT-группы на файлах этой кампании в одном из открытых репозиториях малвари получена ручным ретроспективным поиском одним репортёром и не подтверждена независимыми движками анализа — в этом отчёте и далее мы эту атрибуцию не используем.

Прокси-абьюз специализировался: объём проброса TCP-соединений (direct-tcpip) снизился на 39%, но вместо тысяч случайных проверок работают три устойчивых оператора — скрейпинг крупных веб-

порталов, проверка живости публичных DNS-резолверов и новое явление — проверка открытого SMTP-релея на облачных корпоративных почтовых платформах, которого в июле не было.

На узле, эмулирующем MikroTik RouterOS, зафиксирован всплеск с русскоязычным словарём логинов (13-22 августа), похожий по почерку на брутфорс уже заражёнными российскими роутерами по словарю российских же организаций. Это рабочая гипотеза, не подтверждённая заражением конкретных хостов: из данных подтверждены только источник, объём всплеска и содержание словаря.

В словарях логинов третий месяц подряд держится и расширяется тематическая цель: логин «claude» встретился 928 раз, добавился новый логин «openclaw» (514 раз) — боты целенаправленно ищут хосты с развёрнутыми ИИ-агентами, и список целевых имён растёт.

8. Docker-червь / оператор VPSVAULT: смена канала доставки

Падение объёма Docker API на 34% (§4) — не спад активности прежнего оператора, а смена канала. Известный по предыдущим отчётам оператор полностью ушёл с адреса, дававшего 73,6% июльского Docker-трафика (ноль событий с этого адреса в августе), второй адрес того же блока /24 тоже замолчал после 20 августа. Тот же актор при этом впервые засветился напрямую в SSH-сессиях: тот же путь загрузки полезной нагрузки, тот же адресный блок и автономная система, но новый хост командного сервера внутри того же /24 — доказанная преемственность между двумя векторами.

Более слабые, недоказанные тем же уровнем пивота сигналы указывают на вероятную активность того же почерка ещё в двух сервисах флота (LLM-приманка и MikroTik-эмулятор) — те же типовые пробы, но без общего payload, отпечатка или ключа, который связывал бы их с ядром кампании так же напрямую, как Docker и SSH.

Независимая проверка по метрике активности командных серверов подтверждает: текущий C2 оператора был активен непрерывно весь период с 12 по 31 августа, доминируя над остальным списком командных серверов месяца более чем на порядок — то есть кампания шла с начала окна наблюдения без пауз, а не только со второй половины месяца, как могло показаться по одним лишь логам конкретных сервисов.

Отдельно, несвязанный актор развернул в Docker-приманке чисто CPU-майнер Monero без попытки выхода на хост (без флагов повышенных привилегий и монтирования файловой системы хоста) — fallback на китайский зеркальный сервис GitHub указывает на китаеязычного оператора. Другой актор продолжает похищать файл теневого паролей через монтирование корня файловой системы хоста только для чтения — у него совпадает отпечаток HTTP-клиента с червём основного оператора, что может говорить об общем инструментарии либо об общем операторе, но само по себе это не сильнее совпадения отпечатка.

9. Малварь-конвейер

WannaCry по SMB/Dionaea — постоянный глобальный фон заражённых хостов на 445/tcp; точный счёт уникальных образцов методически спорный (см. §4 — частичные захваты одного и того же файла дают разные хеши на каждый обрыв передачи), но семейство подтверждено надёжно.

Поведенческий анализ показывает, что даже сильно повреждённые перехваченные копии остаются исполняемыми: повреждения приходятся на некритичные секции ресурсов, а заголовок и код целы.

RedTail (разбор — §7): SSH-персистентность + майнер Monero, доставка целиком по SFTP, пять архитектур, 27 перепакowanych копий системного демона sshd.

Mirai/Gafgyt-семейство: мультиархитектурные ELF-бинарии (в августе наблюдались в том числе архитектуры SPARC и PowerPC), дропзоны крупнейшего дроппер-оператора месяца и источник, мимикрирующий под системные демоны с перепакровкой на каждый запрос (§7).

Полиморфные дропперы оператора VPSVAULT — новая техника у известного оператора: 50 bash-скриптов ровно по 1 608 байт с текущей дропзоны (продолжение июльского Docker-червя, тот же адресный блок и автономная система), в каждом — 12 уникальных шестизначных hex-имён, итого 600 URL, ни одного повторяющегося. Блоклист по URL и по хешу против этого не работает, работает только блокировка по IP.

Общая оценка на август: около 180 уникальных вредоносных артефактов (диапазон 178-192 в зависимости от того, как считать частичные SMB-захваты) — оценка, скорректированная вниз против черновых внутренних подсчётов методом простого подсчёта хешей; называть точку внутри диапазона нельзя, это оценка, а не установленный факт.

10. Фишинг: тренды месяца

Новый раздел месячного отчёта. Мы отслеживаем почтовые ящики нескольких партнёрских организаций по их прямому запросу; ниже — обобщённая картина по темам, техникам и инфраструктуре операторов, без привязки к конкретным доменам, организациям или адресам получателей.

10.1 Масштаб

За август зафиксировано порядка 40 самостоятельных кампаний с реальной посадочной страницей или вредоносной нагрузкой — из существенно большего потока сырых писем, включающего фоновый B2B-спам и самоспущ собственной исходящей почты организаций, ошибочно попадающий в статистику. Против одной из отслеживаемых организаций в августе одновременно и независимо действовало восемь и более операторов — против трёх в июле. Общий поток входящей почты по отслеживаемым ящикам снизился на 31% день-к-дню к июлю; число алертов с высоким скором (после исключения ошибочно засчитанных самоспуфов) снизилось на 13%.

10.2 Ключевые сюжеты месяца

- Веерная адресная кампания. Один оператор эксплуатировал тему «истёк срок регистрации email/хостинга» и разослал персонализированные письма по нескольким региональным почтовым алиасам одной организации — тема письма была подставлена под каждого получателя индивидуально.
- AiTM-прокси против логина Google. Один из операторов развернул живой реверс-прокси перед официальной страницей входа Google, который крадёт сессионную куку сразу после ввода пароля — многофакторная аутентификация от такой схемы не спасает. Кампания пришла через скомпрометированную стороннюю Google-группу, вообще без подделки отправителя.
- Компрометация деловой переписки (BEC) против финансовой функции. Единственный алерт месяца по одному из отслеживаемых ящиков — попытка подмены счёта через скомпрометированный аккаунт легитимного email-сервиса с валидной DKIM-подписью. Тот же пресет темы и тот же адресат фигурировали и в июле — устойчивая адресная линия против финансового отдела, а не разовая рассылка.

- Малварь-линия с единой инфраструктурой отправки. Одна и та же вьетнамская инфраструктура на протяжении месяца сменила формат вредоносной нагрузки с исполняемого файла в поддельном архиве на JS-загрузчик — при этом IP-адрес отправки не менялся, что и позволило связать волны между собой.
- Адресный сбор пароля на один ящик. Один конкретный почтовый ящик одной из организаций получил пять независимых линий атаки за месяц; его адрес был напрямую зашит в URL каждой из посадочных страниц.
- Продолжающаяся бренд-кампания. Кампания под брендом Meta/Facebook против организации из некоммерческого сектора идёт без изменения техники с начала июля, с персонализацией по имени организации и её странице в соцсети — меняются только домены посадочных страниц.

Ни по одной из атрибутированных линий признаков state-aligned таргетинга не найдено: весь набор операторов — коммерческий коммодити-фишинг по перекупленным спискам, с той лишь особенностью, что отдельные операторы явно персонализируют рассылку под конкретную организацию или даже конкретный ящик.

10.3 Тенденция: чужая инфраструктура вместо своей

Число одновременно активных операторов против одной из организаций выросло с трёх до восьми и более. Посадочные страницы всё чаще размещаются не на собственном хостинге атакующих, а на легитимных облачных платформах — объектных хранилищах, PaaS-платформах для фронтендов, IPFS-шлюзах и CDN; в августе собственный домен под кит завёл только один оператор, и тот прожил менее пяти суток до блокировки регистратором. Эксфильтрация переехала туда же: формы захвата размещаются на сторонних сервисах веб-форм, часть операторов отправляет украденное прямо в Telegram через Bot API. Блокировать по домену эксфильтрации в этой схеме нечего — используются легитимные публичные сервисы.

Два канала доставки в августе обошлись вообще без подделки отправителя: письма шли через скомпрометированные корпоративные почтовые ящики на легитимном домене и через угнанные сторонние Google-группы — аутентификация письма (SPF/DKIM/DMARC) в обоих случаях проходит полностью. Вместо маскировки от автоматического анализа операторы теперь чаще используют защиту от самого анализа: капчи, режим CDN «под атакой», слайдер-гейты и блок-листы по автономным системам (в отдельных случаях — включая сами Google и Meta) и по географии источника запроса.

11. Рекомендации

- Не выставлять VNC в интернет. Где удалённый доступ к рабочим местам необходим — только через VPN с многофакторной аутентификацией. Распределённый подбор пароля с равномерной нагрузкой на десятки/сотни адресов не превышает порог срабатывания ни на одном отдельном IP.
- Агрегировать неудачные попытки входа по автономной системе и адресному блоку, а не только по IP — состав кампаний месяца показывает, что оператор способен полностью сменить набор адресов, сохранив интенсивность.
- Docker API не должен быть доступен из интернета ни при каких условиях; если удалённое управление необходимо — только TLS с клиентскими сертификатами и списком разрешённых адресов.
- Не выставлять открытые LLM-серверы (Ollama, llama.cpp и совместимые) без аутентификации и без ограничения на пути /api/pull, /api/create — эти пути в августе стали основным вектором traversal и SSRF к облачным учётным данным. Обновиться до версии Ollama, закрывающей CVE-2024-37032.
- Ограничивать исходящий SNMP-трафик приманок/устройств и вводить суточный бюджет ответов на неаутентифицированные запросы — устройство, отвечающее на SNMP-запрос с

произвольным спуфленным адресом источника, работает усилителем DDoS-атаки против третьих лиц.

- В сегментах, прилегающих к промышленным протоколам, начинать инвентаризацию не с самого протокола АСУ ТП, а со средств удалённого доступа персонала — нагрузка на remote-desktop-поверхность в августе на порядки превысила внешнюю нагрузку на промышленный протокол.
- Отключить аутентификацию по паролю в SSH. Основная доля брутфорса — словарные атаки, полностью нейтрализуемые переходом на ключи.
- Учитывать SFTP как самостоятельный канал доставки малвари: детект, построенный только на дроппер-URL в командах shell, пропускает загрузку бинарей напрямую по SFTP.
- Для защиты от кражи сессионной куки через adversary-in-the-middle-прокси переходить на аппаратные ключи (FIDO2/WebAuthn) там, где это возможно — классический одноразовый код такую схему не останавливает.
- Настроить строгий DMARC-выравнивание и мониторинг компрометации сторонних email-сервисов (транзакционная рассылка, ESP-аккаунты) — BEC-кампания месяца против финансовой функции прошла через валидный DKIM скомпрометированного легитимного отправителя.
- Обучать сотрудников распознавать письма о «истечении срока» хостинга/почты/подписки с индивидуальной персонализацией по имени получателя — это была рабочая техника массового веерного фишинга месяца.

12. MITRE ATT&CK

- T1595.002 — Active Scanning: Vulnerability Scanning
- T1190 — Exploit Public-Facing Application
- T1610 — Deploy Container
- T1611 — Escape to Host
- T1110.001 — Brute Force: Password Guessing
- T1021.005 — Remote Services: VNC
- T1021.004 — Remote Services: SSH
- T1046 — Network Service Discovery
- T1105 — Ingress Tool Transfer
- T1027.002 — Obfuscated Files or Information: Software Packing
- T1496 — Resource Hijacking
- T1552.001 — Unsecured Credentials: Credentials In Files
- T1552.005 — Unsecured Credentials: Cloud Instance Metadata API
- T1098.004 — Account Manipulation: SSH Authorized Keys
- T1498.002 — Network Denial of Service: Reflection Amplification
- T0846 — Remote System Discovery (ICS)
- T0888 — Remote System Information Discovery (ICS, General Interrogation)
- T1566.001 — Phishing: Spearphishing Attachment
- T1566.002 — Phishing: Spearphishing Link
- T1539 — Steal Web Session Cookie
- T1585.002 — Establish Accounts: Email Accounts
- T1567 — Exfiltration Over Web Service
- T1090 — Proxy

13. Индикаторы компрометации

Индикаторы ниже приведены в обезвреженном (defanged) виде. Машиночитаемые дампы — iocs.stix2.json (STIX 2.1) и iocs.misp.json (MISP) — поставляются вместе с отчётом в рабочем (refanged) формате. Публикация действующих командных серверов в этом цикле согласована отдельно. Адреса и идентификаторы, способные раскрыть расположение или архитектуру наших собственных сенсоров, из индикаторов исключены.

13.1 LLM-абьюз (Ollama)

Индикатор	Контекст
147[.]45[.]69[.]42 (AS210644, санкционирован)	46,5% объёма месяца; повторяющийся запрос «What is 3+3?»
168[.]144[.]135[.]119	Traversal к облачным AWS/GCP-кредам через /api/pull
208[.]84[.]103[.]51	Traversal / попытки эксплуатации
8[.]219[.]90[.]108	Go-template-инъекция ({{readFile "/etc/passwd"}})
156[.]239[.]42[.]225	Попытка записи в ~/.ssh/authorized_keys через имя модели
151[.]231[.]112[.]236	Traversal к id_rsa
136[.]243[.]10[.]183	SSRF к cloud-metadata (AWS/GCP)
74[.]80[.]181[.]141, 199[.]217[.]105[.]247	Кампания-вымогатель «deadbugz»
103[.]124[.]110[.]245, 103[.]124[.]110[.]246	Бот для ставок на прогнозном рынке
BTC: bc1q5xpazlg7q6ph2r6s7tzumd5zyj det6vjzvsqIn	Кошелёк кампании deadbugz — 0 транзакций на момент проверки

13.2 ICS: VNC-кампания и SNMP-отражение

Ядро кампании, замолчавшее с 21 августа: 140[.]235[.]17[.]25/.49/.65, 140[.]235[.]18[.]105/.166, 140[.]235[.]19[.]17, 207[.]174[.]1[.]227-231, 207[.]174[.]2[.]239/.241, 207[.]174[.]3[.]248, 72[.]51[.]57[.]6, 72[.]51[.]59[.]6.

«Тяжёлая дюжина» (синхронное включение, каждый в своей автономной системе и стране):

188[.]130[.]208[.]33, 104[.]128[.]190[.]153, 37[.]187[.]3[.]25, 37[.]58[.]131[.]227, 103[.]103[.]245[.]226, 103[.]160[.]37[.]151, 183[.]178[.]3[.]113, 169[.]38[.]135[.]196, 165[.]165[.]142[.]149, 192[.]3[.]154[.]34, 94[.]154[.]43[.]191, 93[.]48[.]225[.]80.

SNMP-отражение, спуфленные-как-источник адреса приманки, использованные для усиления (блокировать неаутентифицированный SNMP на этих и подобных устройствах, не сами адреса):

185[.]242[.]3[.]3/.200/.202/.203, 43[.]228[.]157[.]74, 45[.]194[.]67[.]120, 45[.]205[.]1[.]231, 5[.]42[.]211[.]96, 152[.]89[.]199[.]131.

13.3 SSH и ботнеты

Главный оператор SSH-брутфорса месяца — блоки 91[.]92[.]40[.]0/24, 91[.]92[.]42[.]0/24, 91[.]92[.]47[.]0/24, 45[.]153[.]34[.]0/24, 45[.]156[.]87[.]0/24. Дроппер-канал «nerv»: 171[.]244[.]44[.]251.

Мимикрия под системные демоны: 213[.]232[.]114[.]14. Крупнейший дроппер-оператор:

176[.]65[.]139[.]228:6677, 176[.]65[.]139[.]202, 94[.]154[.]43[.]231:3001, 94[.]154[.]43[.]238. RedTail (SFTP-доставка): 130[.]12[.]180[.]51. Прочие устойчивые кластеры: 195[.]178[.]110[.]0/24, 92[.]118[.]39[.]0/24, 193[.]32[.]162[.]0/24, 2[.]57[.]122[.]0/24, 80[.]94[.]92[.]0/24, 77[.]239[.]124[.]0/24.

XMRig-контейнер: 64[.]112[.]184[.]210, кошелёк

8AQRM4ZiDAXwLhiuSAyCBfdQC1MFbQAYktNqtN3De1pSYrWxXzaMjjMSm2THvviW52tPXTSfgSY6UqJ
 хouc1vVpBN5MuJG, пул pool[.]supportxmr[.]com:3333. Гипотетический самозамкнутый ботнет на
 MikroTik-эмуляторе: 83[.]237[.]93[.]10.

Хеши RedTail (SHA-256, мульти-архитектурные копии sshd):

f0aa83bbbd2c75e2f71ec16029ee5fcfad59f3a8efa30a500b815f0f6c18d987 (x86_64) ·

3f3bf218089d1488617d37f8a5116bb2791eb39ce06a1b5bc9a4cdfe5e94dd39 (riscv) ·

8e1a67a5c03b3cd818f046c7a1605afccc0ee5ce437a0d099881f1872b54bc70 (i686) ·

d1cac82f44b54b0fd244a9e4122811e9ae108a197c7a65a20fd2e7552683e68e (arm8) ·

d70f917e35813a7ae323e6b2b539d6dbbfc3a3a6599f1fed93430b14ca08b141 (arm7). Атрибуция этих

файлов известной АРТ-группе по одному источнику в открытом репозитории малвари не
 подтверждена независимыми движками и здесь не используется.

13.4 Docker-червь / оператор VPSVAULT

Текущий командный сервер, подтверждён живым и непрерывно активным весь период 12-31

августа: 5[.]182[.]210[.]174 (путь /ok). Прежний, июльский C2: 5[.]182[.]210[.]61 (в августе не

наблюдался). Исполнитель Docker-канала: 45[.]198[.]224[.]26 (стих после 20.08); 45[.]198[.]224[.]15

(отсутствовал весь август). Вероятно тот же оператор (не доказано тем же уровнем пивота):

154[.]90[.]70[.]254 (LLM-приманка), 45[.]205[.]1[.]240 (MikroTik-эмулятор). Отпечатки HTTP-клиента

(JA4H): po11nn060000_46ba010406bc, po11nn050000_2c3038913033. Прочие живые C2 месяца, на

порядок-два ниже по объёму: 154[.]54[.]100[.]247, 217[.]60[.]195[.]113 (тот же C2, что и в июльском

отчёте — кампания не закрылась), 101[.]33[.]245[.]191, 167[.]86[.]122[.]134.

13.5 Фишинг

Инфраструктура отправки (IP): 36[.]255[.]97[.]120 · 77[.]83[.]39[.]10/.14/.15/.17/.24/.45/.81 ·

198[.]135[.]51[.]150 · 45[.]74[.]252[.]189 · 65[.]181[.]122[.]48 · 152[.]89[.]218[.]91 · 108[.]59[.]4[.]205 ·

66[.]181[.]39[.]225 · 95[.]217[.]203[.]83 · 5[.]230[.]201[.]163 · 5[.]175[.]182[.]215 · 192[.]227[.]144[.]55 ·

172[.]245[.]92[.]100 · 198[.]135[.]55[.]67 · 135[.]181[.]7[.]237 · 136[.]243[.]200[.]190 · 160[.]30[.]136[.]41 ·

160[.]30[.]136[.]11 (инфраструктура malware-линии, ключ склейки двух волн одной кампании) ·

144[.]31[.]63[.]120 · 204[.]152[.]214[.]27 · 150[.]241[.]230[.]186.

Посадочные страницы и send-домены, выделенная инфраструктура операторов (блокировать домен
 целиком): fifapredict[.]live, richiedabie[.]com, hulladolsentenpe[.]top (AiTM-прокси перед логином Google,

плюс поддомены-подделки под почтовые/облачные сервисы), v1ad0bv1[.]jes, meta-iden[.]com, meta-

ids[.]com, meta-mailcontact[.]com, meta-betamax[.]com, meta-securitypage[.]com, facebook-security[.]date,

verified-blue-badge[.]com, sellpia247[.]com, st[.]sellpia247[.]com, meta-security-mail[.]com, fb-security-

blud[.]netlify[.]app, fb-copyright-page[.]netlify[.]app, facebook-verified-badge[.]center,

facebookbadgeapply[.]com, solidfairhubhost[.]com, coredatfye[.]com, domainswitchmove[.]com,

mail[.]logiswebmail[.]top, hatsmtpl[.]top, global[.]traders[.]ca, secure[.]ambergmarktber[.]store,

project22499886[.]tilda[.]ws.

Взломанные легитимные сайты, использованные как посадочная площадка — блокировать

конкретный путь, не домен целиком: habitatcyprus[.]com, nelsonequity[.]com (kit-путь

/webverify/pageme/fased.html), sameylogistics[.]com, login[.]2ccloud[.]com. Двухступенчатая посадка:

flixx-fox[.]com[.]in → read0nsession[.]jes.

Хеши вложений malware-линии (SHA-256):

530d00da82a188bd6ff7dc3a1cc0b6216d8f9a279f7d00213bbc68acd09d2f71 ·
f3cfcdbd8c2d33128a836f891791a1743c427f321f538dc208521c371edd03d7f ·
df7ec7857c3e6c3679ad50c60fbd97f322eca68f1c893c1b9c8ee7aa05a0a656 ·
b3999441143b2dd9788d4dca2a538c349d68d0f6d3ce4bd61a3fc5c134445307 ·
0667e9dba7e3bfcd004aa5f50e462a52efd01fa9ddd1c97d533e6db5ee0bc977 ·
ffaddf3882cdd59a4b685e7215bedee8b4b84f10ae4644d37e937755d8cb6d32 ·
a601ae5011cec30fd1f3af31830e733e339e59e4bc9e3461cca383c99e06bfa3 ·
3ed1a5df1dfb1a5a345fdea33b97eff013c3ec08a415b73312b82daa1d13a792 ·
1219a58a2c598567bad7d06fa7f29769e613e279b5623df6302f2f4bb6594069 ·
4721cafc6efbf3435a188af4a7e71722c8b647bcdfd4948e8c02a38bc2e7ebd1 ·
c9826b12efd1a694159e1e2fd7b215045ed85dc92f0a4e52b9639bcbe2277264 ·
b3c7e130a3a6b609c21175e978d307f8efc9a11c5286e08898e045dbc6352fb4 ·
ab51b26c0fc15403dae63cf40a28a09bd85c624d5929cddf11537688f1b76f8b ·
3f746415957b5f2abbce7baeb6edd5232411372a5c1c0c04a319c6bedd8974e9 ·
bfc48971d3254861637e5e370ff2d522defe0b28d566c7b76c4bea7d7195aaf7.

BTC-кошельки sextortion-кампании (4 волны, одна подтверждённая оплата):

bc1qw6l8m0u9720l7p6l8nw3trcesgt2rxshvr7xrd · bc1q5t0peymgrvzd49e4zgwxxnwrac7n4sc45fufwvr
(подтверждённая оплата) · 1DFN2R8w1Qos6Cwi4kp68ACZLSHHFeaRFq ·
bc1qk34llhm32cmj8t3m652wdz884hy565d6skv2de.

Инфраструктура на легитимных общих платформах (Formspark, Backblaze B2, Google Cloud Storage, Pipedream, IPFS, Framer, Netlify, Vercel) намеренно не включена в индикаторы поадресно: блокировка домена платформы затронула бы легитимных пользователей сервиса, а конкретные идентификаторы (ID формы, bucket, CID) меняются от кампании к кампании быстрее, чем имеет смысл публиковать.

TLP:CLEAR — Этот документ может распространяться без ограничений.